

Introducción a la Ciberseguridad



Introducción a la ciberseguridad

Ing. Deyler Roca M.
COM-500 / COM-560
Cybersecurity

PROTECCION DE LA ORGANIZACIÓN FIREWALL



Un firewall (cortafuegos) es un muro o partición diseñada para evitar que el fuego se propague de una parte a otra de un edificio.

En las redes de computadoras, un firewall está diseñado para controlar o filtrar la entrada o salida de comunicaciones de un dispositivo o una red, como se muestra en la figura

Un firewall puede instalarse en una única computadora con el propósito de proteger dicha computadora (firewall ejecutado en un host) o puede ser un dispositivo de red independiente que protege toda una red de computadoras y todos los dispositivos host en dicha red (firewall basado en la red).



PROTECCION DE LA ORGANIZACIÓN FIREWALL

Esta es una lista de los tipos de firewall comunes:

Firewall de capa de red: filtrado basado en las direcciones IP de origen y destino.

Firewall de capa de transporte: filtrado basado en puertos de origen y datos de destino y filtrado basado en los estados de conexión.

Firewall de capa de aplicación: filtrado basado en la aplicación, el programa o el servicio.

Servidor proxy: filtrado de solicitudes de contenido web, como URL, dominio, medios, etcétera.

Firewall de traducción de direcciones de red (NAT): ocultan o enmascaran las direcciones privadas de los hosts de red.

Firewall basado en host: filtrado de puertos y llamadas de servicio del sistema en el sistema operativo de una computadora.

PROTECCION DE LA ORGANIZACIÓN

Escaneo de puertos

Resultados del escaneo de puertos Nmap

The screenshot shows the Nmap output for target 192.168.3.61. The interface includes tabs for Hosts, Services, Nmap Output, Ports/Hosts, Topology, Host Details, and Scans. The 'Nmap Output' tab is selected, displaying the following information:

```
nmap -T4 -A -v 192.168.3.61
Nmap scan report for 192.168.3.61
Host is up (0.0010s latency).
Not shown: 997 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.7p1 Raspbian 5 (protocol 2.0)
ssh-postkey:
  1024 05:7e:2f:05:9c:ec:30:43:0c:08:a6:90:dd:5d:48:43 (DSA)
  2048 80:16:3e:41:09:ac:30:9c:0a:58:a0:a5:ad:b4:3f:4b (RSA)
  256 08:f1:01:b3:fb:4d:15:57:cd:a2:52:a7:fc:b9:1a:15 (ECDSA)
80/tcp    open  http         Apache httpd 2.4.18 ((Raspbian))
http-methods:
  Supported Methods: OPTIONS GET HEAD POST
  _http-server-header: Apache/2.4.18 (Raspbian)
  _http-keep-alive: on
3389/tcp  open  ms-wbt-server xrdp
MAC Address: 08:00:27:1b:77:13:18 (Raspbian Pi Foundation)
Device type: wireless_nanoos
Running: Linux 3.X|4.X
OS SPS: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.0
Uptime guess: 6.004 days (since Tue Mar 01 09:52:48 2016)
Network Distance: 1 hop
TCP Sequence Prediction: Difficulty=261 (Good luck!)
IP ID Sequence Generation: All zeros
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 1.90 ms 192.168.3.61

NSE: Script Post-scanning.
Initiating NSE at 09:58
Completed NSE at 09:58, 0.00s elapsed
Initiating NSE at 09:58
Completed NSE at 09:58, 0.00s elapsed
```

Annotations on the left side of the screenshot point to specific parts of the output:

- Servicio/puerto abierto y SO: Points to the 'ssh' service and 'OpenSSH' version.
- Servicio/puerto abierto: Points to the 'http' service and 'Apache httpd' version.
- NIC/Plataforma: Points to the 'Raspbian Pi Foundation' MAC address.
- Núcleo del SO: Points to the 'Linux 3.X|4.X' running OS.

El escaneo de puertos es un proceso de **comprobación** de una computadora, un servidor u otro host de red para **conocer los puertos abiertos**. En redes, a cada aplicación que se ejecuta en un dispositivo se le asigna un **identificador llamado número de puerto**. Este número de puerto se utiliza en ambos **extremos de la transmisión**, para, asegurar que los datos estén llegando a la aplicación correcta.

PROTECCION DE LA ORGANIZACIÓN

Escaneo de puertos...

```
NSEarch
Version 0.3 | @jjtibaquira

nsearch> search name:ftp
1.ftp-anon.nse
2.ftp-bounce.nse
3.ftp-brute.nse
4.ftp-libopie.nse
5.ftp-proftpd-backdoor.nse
6.ftp-vsftpd-backdoor.nse
7.ftp-vuln-cve2010-4221.nse
8.tftp-enum.nse
nsearch>

root@sideswipe: ~
root@sideswipe:~# nmap -s-script=ftp-anon.nse 192.168.206.133 -p 21
Starting Nmap 6.47 ( http://nmap.org ) at 2015-02-18 14:04 ART
Nmap scan report for 192.168.206.133
Host is up (0.00024s latency).
PORT      STATE SERVICE
21/tcp    open  ftp
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds
root@sideswipe:~#
```

El escaneo de puertos se puede utilizar con fines maliciosos como una herramienta de reconocimiento, para identificar el sistema operativo y los servicios que se ejecutan en una computadora o un host, o se puede utilizar inofensivamente por parte de un administrador de red para verificar las políticas de seguridad en la red.

Con el propósito de evaluar el firewall de la red de computadoras y la seguridad de los puertos, se puede utilizar una herramienta de escaneo de puertos, como **Nmap**, para encontrar todos los puertos abiertos en su red. El escaneo de puertos se puede considerar como precursor para un ataque a la red y, por lo tanto, no debe realizarse en servidores públicos en Internet o en la red de una empresa sin permiso.



PROTECCION DE LA ORGANIZACIÓN

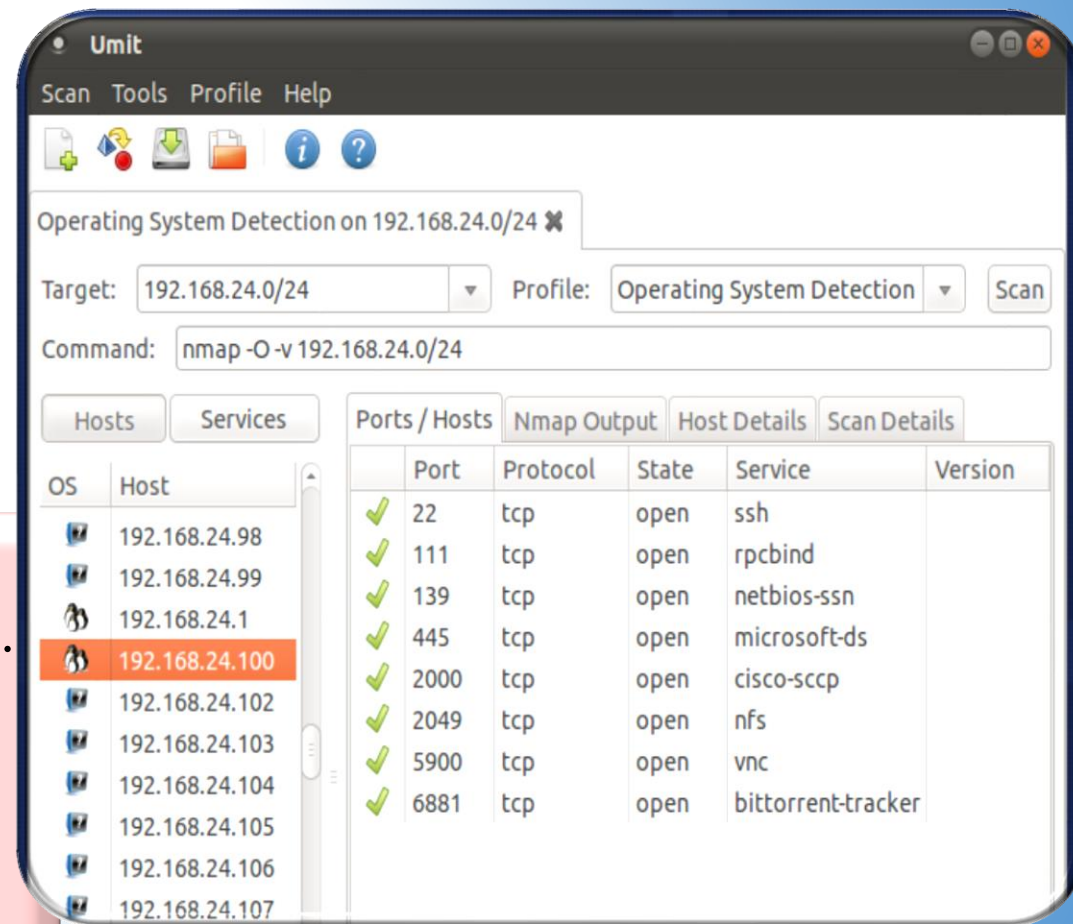
Escaneo de puertos...

Para ejecutar el escaneo de puertos **Nmap** podemos utilizar **Zenmap**, proporcione la dirección IP de destino de la computadora que desea analizar, elija un perfil de escaneo predeterminado y presione Escanear. El escaneo de Nmap reportará cualquier servicio que se esté ejecutando (como servicios web, servicios de correo, etc.) y los números de puerto. El escaneo de puertos generalmente provoca alguna de estas tres respuestas:

Abierto o aceptado: el host respondió e indicó que hay un servicio activo en el puerto.

Cerrado, denegado o no escucha: el host respondió e indicó que se denegarán las conexiones en el puerto.

Filtrado, caído o bloqueado: no hubo respuesta del host.



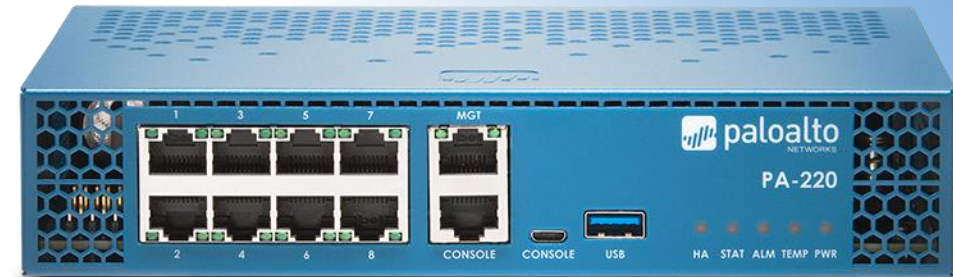
PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.2.- Dispositivos de Seguridad.

Hoy no existe un dispositivo de seguridad o una tecnología que resuelva todas las necesidades de seguridad de la red por sí solo.

Debido a que hay una variedad de dispositivos de seguridad y herramientas que deben implementarse, es importante que trabajen en conjunto. Los dispositivos de seguridad son más efectivos cuando forman parte de un sistema.



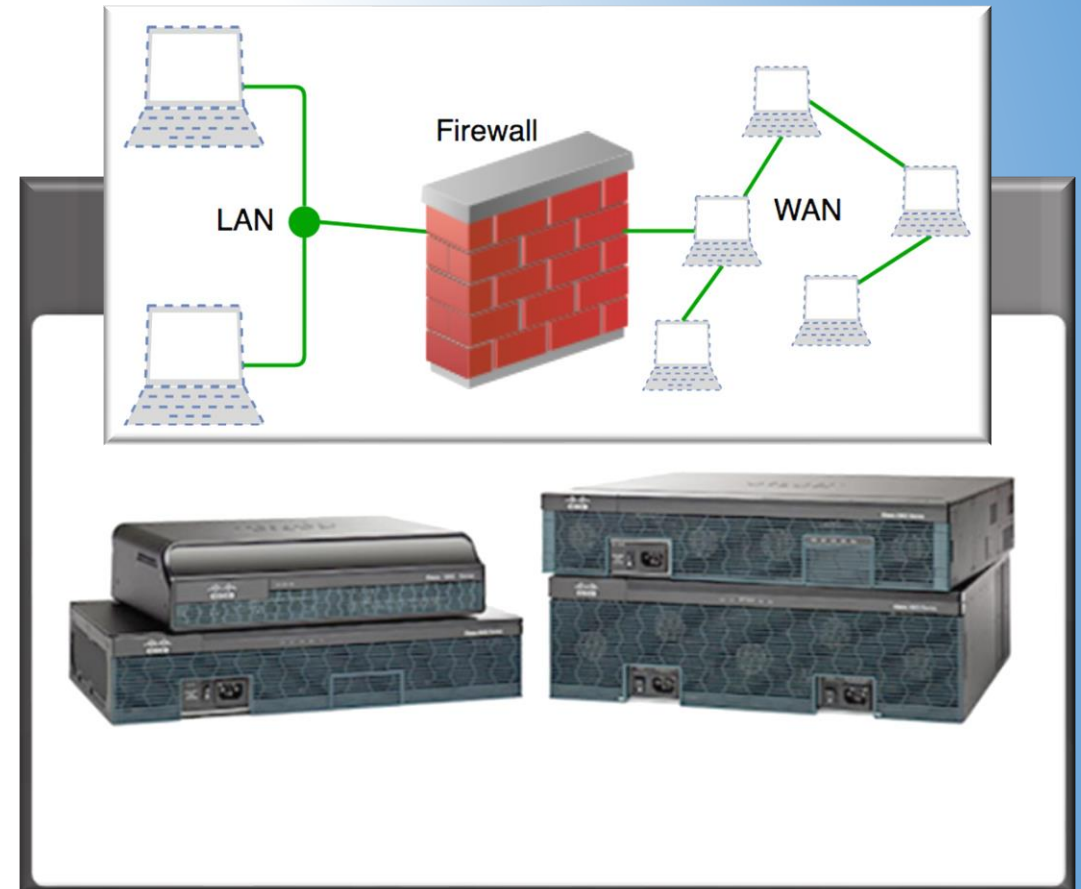
PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.2.- Dispositivos de Seguridad.....

Los dispositivos de seguridad pueden ser dispositivos independientes, como un **Router** o **firewall**, una tarjeta que puede instalarse en un dispositivo de red o un módulo con su propio procesador y memoria en caché.

Los dispositivos de seguridad también pueden ser herramientas de software que se ejecutan en un dispositivo de red. **Los dispositivos de seguridad se dividen en las siguientes categorías generales:**



PROTECCION DE LA ORGANIZACIÓN

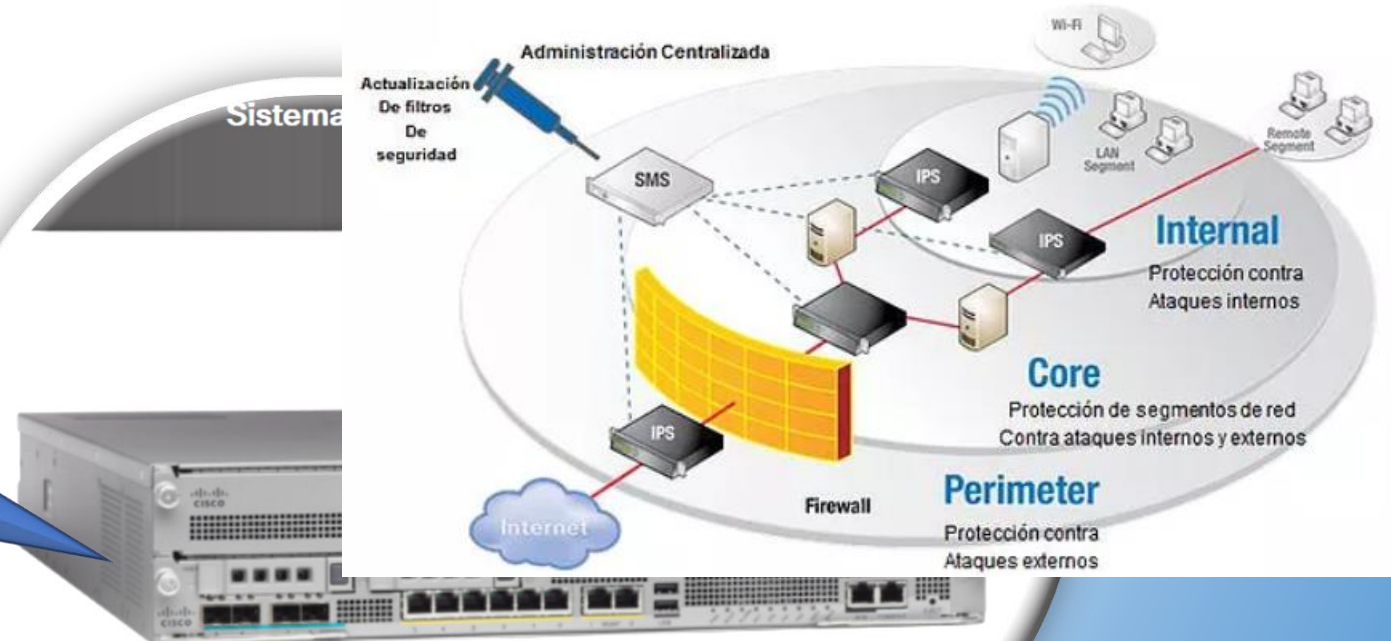
4.1.- Firewalls

4.1.2.- Dispositivos de Seguridad.....

IPS:

Los dispositivos IPS de nueva generación, que se muestran en la Figura 3, están dedicados a la prevención de intrusiones.

Lugar de Prevención de Intrusos en la Red



PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.2.- Dispositivos de Seguridad.....

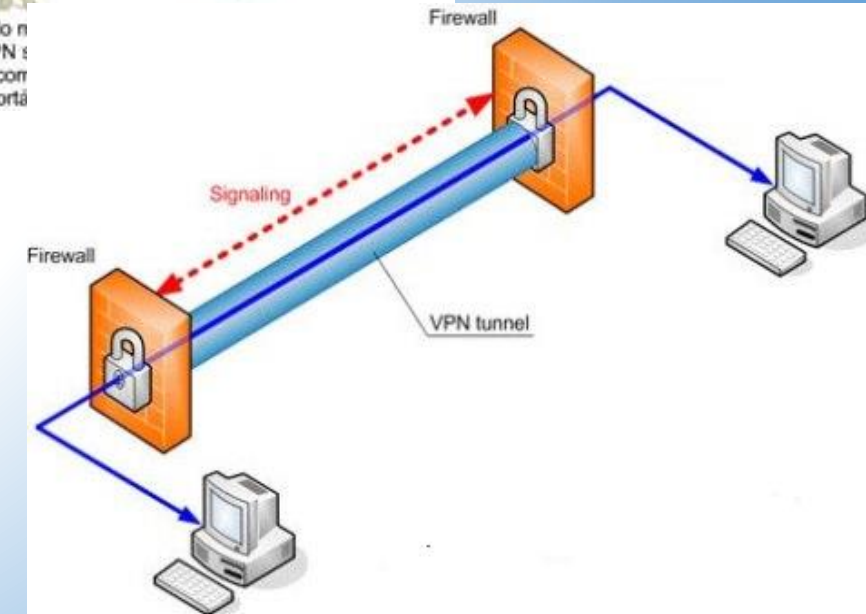
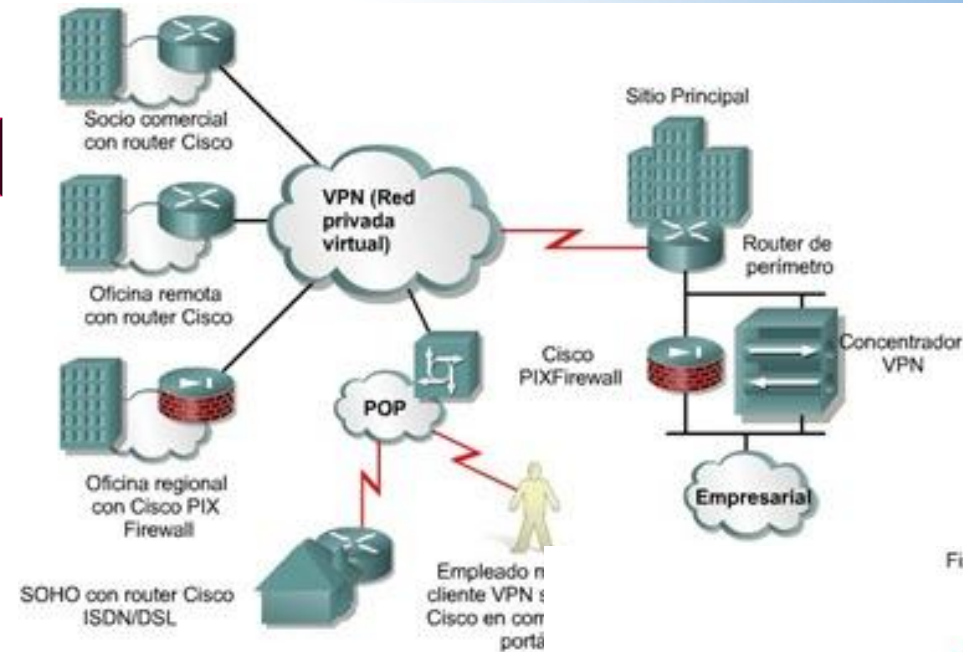
VPN:

Los dispositivos de seguridad de Cisco cuentan también con tecnologías de redes virtuales privadas (VPN) tanto de cliente como servidor. Están diseñados para conexiones de cifrado seguro.

IPsec (*Internet Protocol Security*)

PPTP/MPPE (*Microsoft Point to Point Encryption*)

L2TP/IPsec (*L2TP sobre IPsec*)



PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.2.- Dispositivos de Seguridad.....

Malware/antivirus:

Cisco **Advanced Malware Protection (AMP)** viene en los **Routers** de nueva generación de Cisco, como también en los firewalls, los dispositivos **IPS** y los dispositivos de seguridad web y de correo electrónico y además puede instalarse como software en los equipos host.

Otros dispositivos de seguridad: esta categoría incluye dispositivos de seguridad web y de correo electrónico, dispositivos de descifrado, servidores de control de acceso del cliente y sistemas de administración de seguridad.

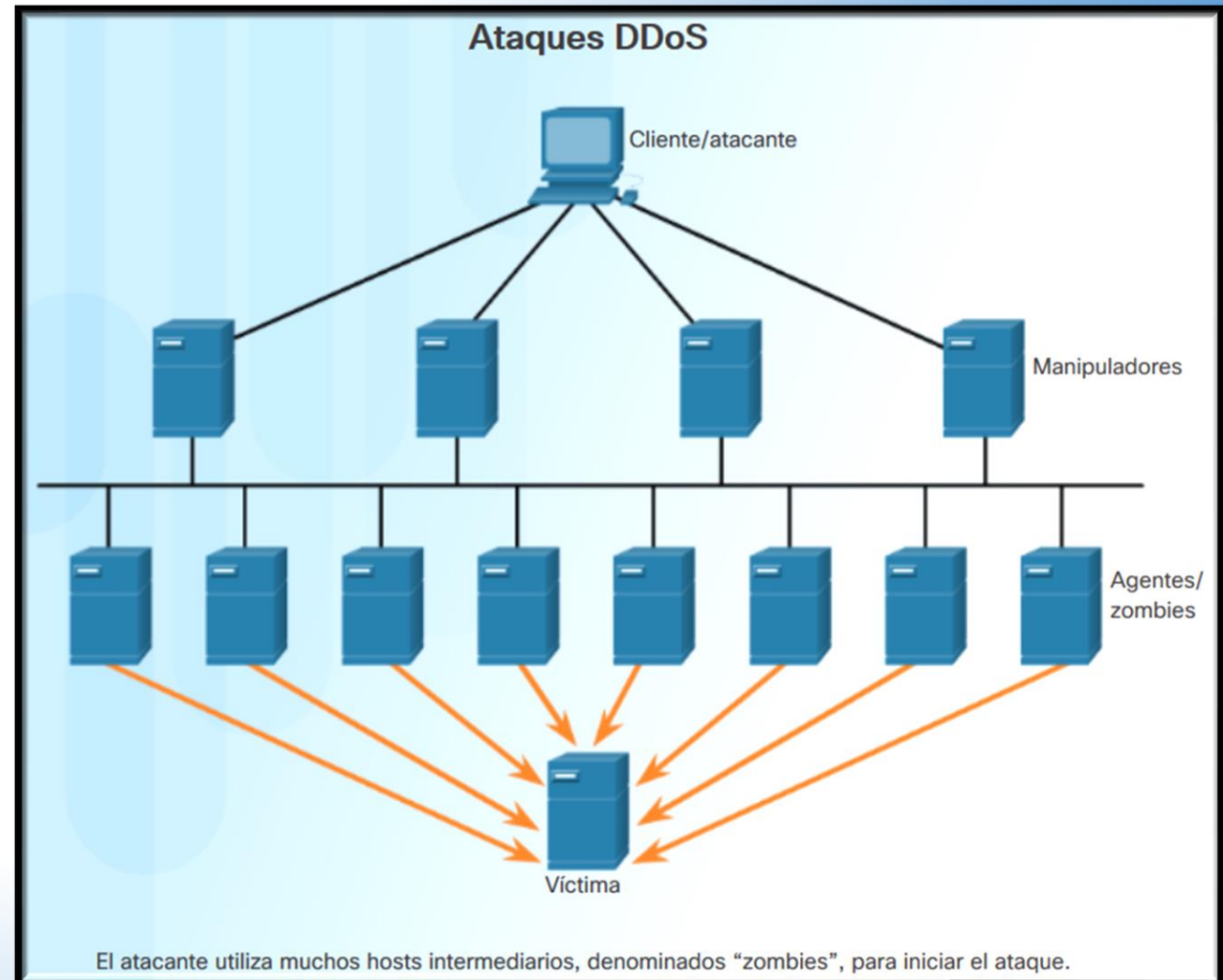


PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.3.1.- Detección de ataques en tiempo real

El software no es perfecto. Cuando un hacker explota un defecto de un software antes de que el creador pueda corregirlo, **se conoce como ataque de día cero**. Debido a la complejidad y tamaño de los ataques de día cero que se encuentran actualmente, no es extraño que los ataques a la red tengan éxito y que el éxito de su defensa ahora se mida según la rapidez con la que una red responde ante un ataque. La capacidad de detectar ataques mientras suceden en tiempo real, así como de detenerlos inmediatamente o en cuestión de minutos, es el objetivo ideal. Desafortunadamente, muchas empresas y organizaciones a día de hoy no pueden detectar los ataques sino hasta días o incluso meses después de ocurridos.



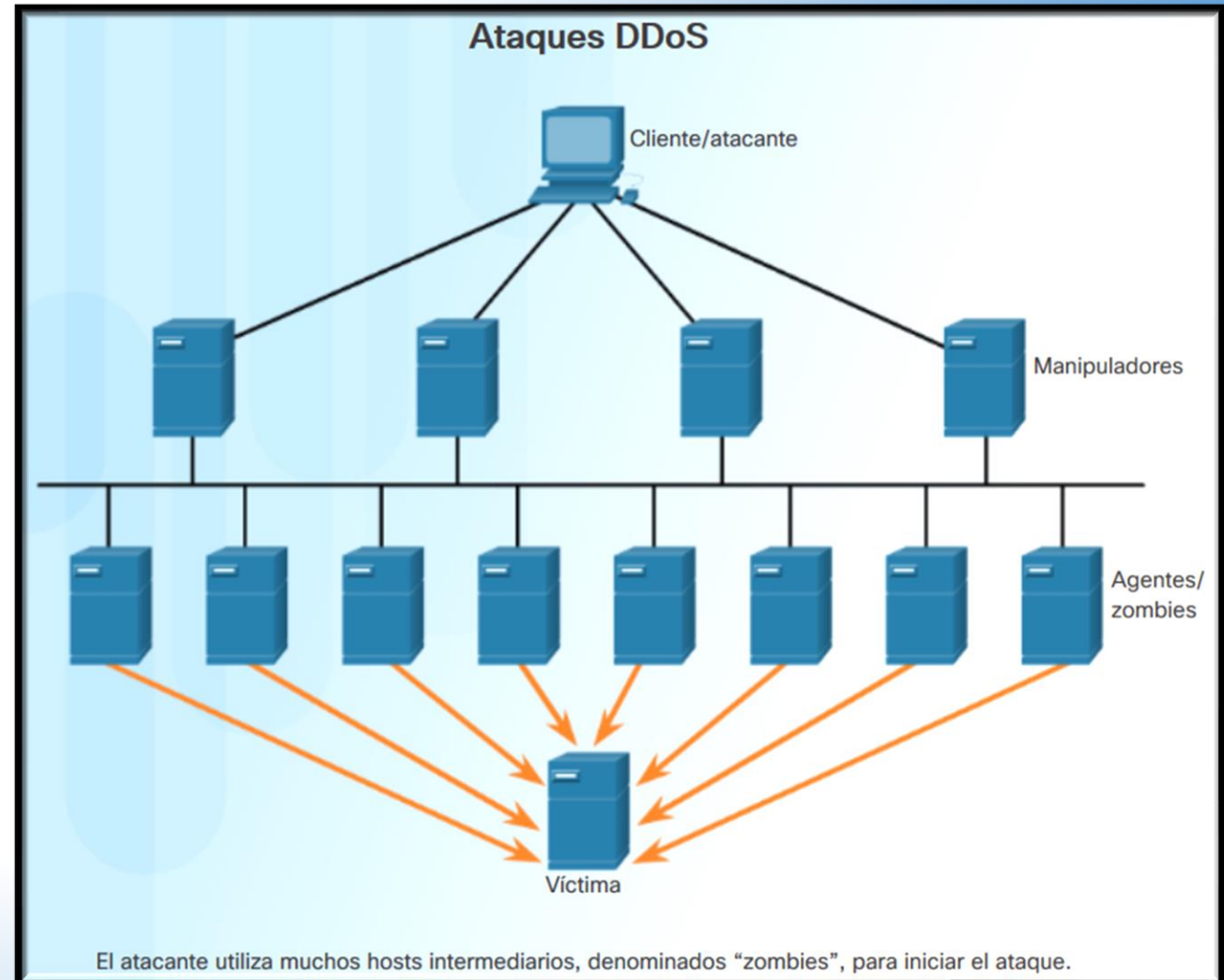
PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.3.1.- Detección de ataques en tiempo real....

* Análisis en tiempo real de principio a fin:

Detectar ataques en tiempo real requiere el análisis activo mediante el **firewall** y los dispositivos de red **IDS/IPS**. También debe usarse la detección de malware de cliente/servidor de nueva generación con conexiones a los centros de amenazas globales en línea. En la actualidad, el software y los dispositivos de análisis activos deben detectar anomalías de red mediante la detección de comportamientos y el análisis basado en el comportamiento.



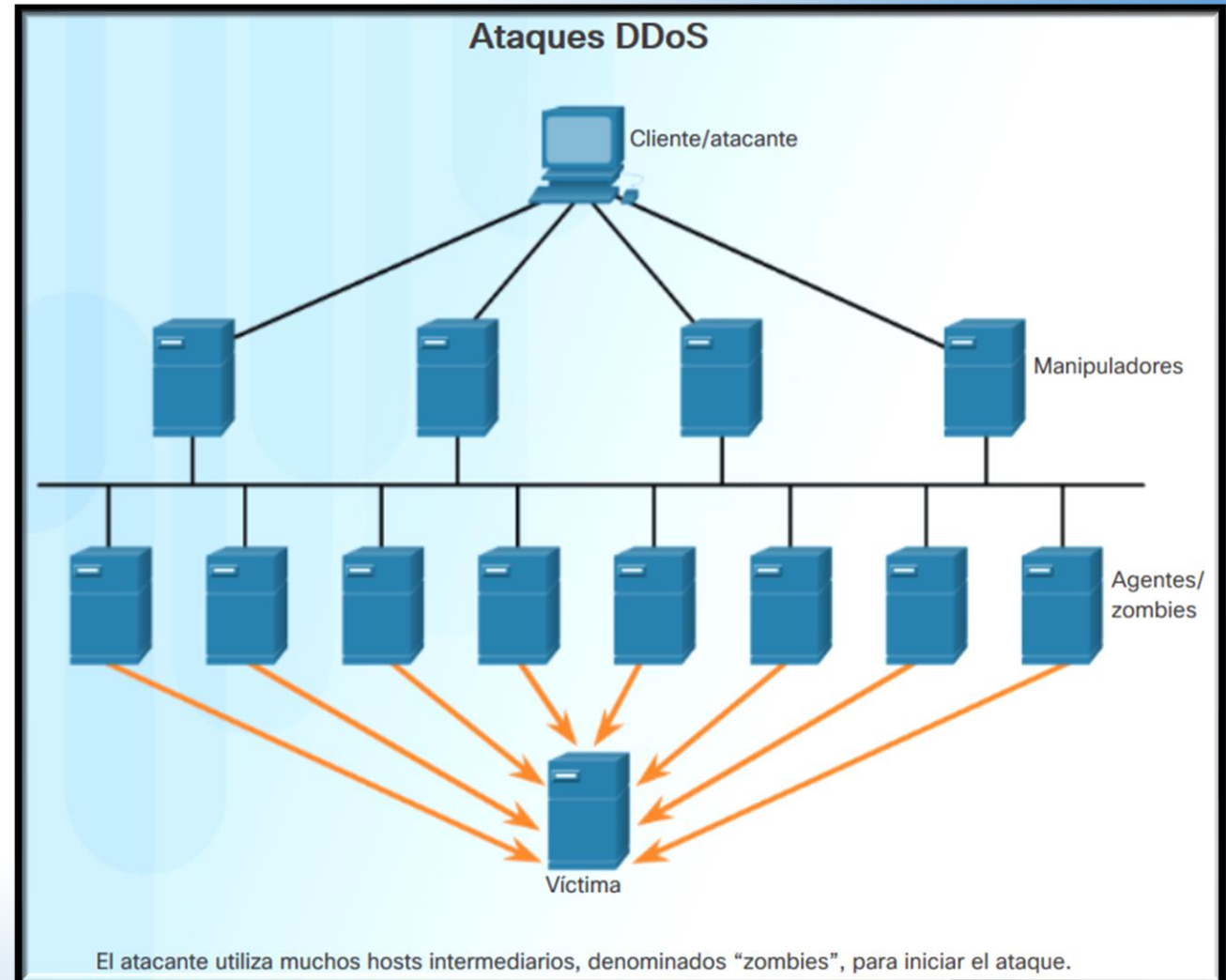
PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.3.1.- Detección de ataques en tiempo real...

* Ataques DDoS y respuesta en tiempo real:

El ataque **DDoS** es una de las mayores amenazas que requiere la detección y respuesta en tiempo real. Es extremadamente difícil defenderse contra los ataques de **DDoS** porque los ataques se originan en cientos o miles de hosts **zombis** y aparecen como tráfico legítimo, como se muestra en la figura. Para muchas empresas y organizaciones, los ataques **DDoS** ocurren de forma regular y paralizan los servidores de Internet y la disponibilidad de la red. La capacidad para detectar y responder a los ataques **DDoS** en tiempo real es muy crucial.



PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.5.1.- Buenas prácticas de seguridad

Muchas organizaciones nacionales y profesionales han publicado listas de buenas prácticas de seguridad. La siguiente es una lista de algunas de las buenas prácticas de seguridad:

- * **Realizar una evaluación de riesgos:** conocer el valor de lo que protege ayuda a justificar los gastos de seguridad.

- * **Crear una política de seguridad:** cree una política que delimite claramente las reglas de la empresa, las tareas y las expectativas.

- * **Medidas de seguridad física:** restringen el acceso a los centros de datos, a las ubicaciones de servidores y a los extintores.

- * **Medidas de seguridad de recursos humanos:** los empleados deben ser correctamente investigados con comprobaciones de antecedentes.

- * **Efectuar y probar las copias de respaldo:** realice copias de respaldo periódicas y pruebe los datos recuperados de las copias de respaldo.

PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.5.1.- Buenas prácticas de seguridad...

* **Mantener parches y actualizaciones de seguridad:** actualice periódicamente los servidores, computadoras, los programas y sistemas operativos de los dispositivos de red.

* **Implementar controles de acceso:** configure los roles de usuario y los niveles de privilegio, así como una autenticación de usuario sólida.

* **Revisar periódicamente la respuesta ante incidentes:** utilice un equipo de respuesta ante incidentes y pruebe los escenarios de respuesta ante emergencias.

* **Implementar una herramienta de administración, análisis y supervisión de red:** seleccione una solución de monitoreo de seguridad que se integre con otras tecnologías.

* **Implementar dispositivos de seguridad de la red:** utilice routers de nueva generación, firewalls y otros dispositivos de seguridad.

* **Implementar una solución de seguridad integral para terminales:** utilice software antivirus y antimalware de nivel empresarial

PROTECCION DE LA ORGANIZACIÓN

4.1.- Firewalls

4.1.5.1.- Buenas prácticas de seguridad...

* **Informar a los usuarios:** educar a los usuarios y a los empleados sobre los procedimientos seguros y seguridad informática y de la información.

* **Cifrar los datos:** cifrar todos los datos confidenciales de la empresa, incluido el correo electrónico.

Algunas de las pautas más útiles se encuentran en los depósitos organizacionales, como el Centro de Recursos de Seguridad Informática del Instituto Nacional de Normas y Tecnología (NIST, por sus siglas en inglés).

Una de las organizaciones más conocidas y respetadas para la capacitación en ciberseguridad es el SANS Institute. Haga clic [aquí](#) para obtener más información sobre SANS y los tipos de capacitación y certificaciones que ofrece.

